Техническое задание: Авторизация сотрудников партнера по ссылке

Краткая информация

Customer	Чиббис
Date	29.01.2026
Design Item Name	Разработка модуля авторизации сотрудников партнера по одноразовой ссылке
Design Item ID	DI-0001
Problem Statement	В настоящее время доступ сотрудников партнёров в Личный кабинет организован через ручную отправку ссылок службой заботы. В системе отсутствует самостоятельный и формализованный механизм идентификации, аутентификации и авторизации пользователей. Текущий подход ограничивает масштабирование продукта, создает дополнительную операционную нагрузку на бизнес-подразделения и повышает риски неконтролируемого доступа. Введение учётных записей сотрудников и механизма авторизации по одноразовой ссылке, направляемой на электронную почту, необходимо для разграничения доступа, использования уникальной информации о пользователях и поддержки ключевых бизнес-процессов Заказчика.
User Story	• Как сотрудник партнера, я хочу получить ссылку для входа на свою электронную почту, чтобы самостоятельно авторизоваться в Личном кабинете без обращения в службу заботы. • Как сотрудник партнера, связанный с несколькими ресторанами, я хочу выбрать ресторан после входа в систему, чтобы работать с данными конкретного ресторана. • Как владелец продукта, я хочу ограничить частоту отправки ссылок для входа, чтобы снизить риски злоупотреблений и атак на систему. • Как сотрудник службы безопасности, я хочу, чтобы ссылки для входа были одноразовыми и ограниченными по времени, чтобы обеспечить безопасный доступ к системе.
Business Requirements	• BR-0001-01: Пользователь должен иметь возможность самостоятельно войти в ЛК без участия службы заботы. • BR-0001-02: Доступ в ЛК должен быть возможен только для сотрудников, email которых заранее заведен в системе. • BR-0001-03: Решение должно масштабироваться на всех партнёров без увеличения операционных затрат. • BR-0001-04: Процесс входа должен быть простым и понятным для пользователей без технической подготовки.

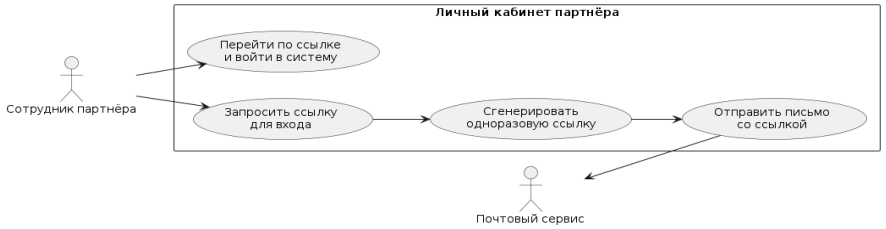
Functional Requirements	• FR-0001-01: Модуль авторизации должен предоставлять пользовательский интерфейс для ввода адреса электронной почты с целью запроса ссылки для входа в Личный кабинет.
	• FR-0001-02: Модуль авторизации должен выполнять проверку наличия введенного адреса электронной почты в системе без раскрытия результата пользователю.
	• FR-0001-03: Модуль авторизации должен генерировать одноразовую ссылку для входа, привязанную к конкретному пользователю.
	• FR-0001-04: Модуль авторизации должен обеспечивать отправку письма со ссылкой для входа через интеграцию с внешним почтовым сервисом.
	• FR-0001-05: Модуль авторизации должен ограничивать частоту отправки ссылок для входа:
	  • не более 5 писем на один адрес электронной почты за 15 минут;
	  • не более 10 писем с одного IP-адреса за 15 минут;
	  • минимальный интервал между отправками — 60 секунд.

	• FR-0001-06: Модуль авторизации должен блокировать повторное использование одноразовой ссылки после успешного входа пользователя. • FR-0001-07: Модуль авторизации должен проверять срок действия одноразовой ссылки при каждом обращении. • FR-0001-08: Модуль авторизации должен обеспечивать срок действия одноразовой ссылки не более 15 минут с момента генерации. • FR-0001-09: Модуль авторизации должен автоматически создавать пользовательскую сессию после успешной проверки одноразовой ссылки. • FR-0001-10: Модуль Личного кабинета должен предоставлять пользователю интерфейс выбора ресторана в случае, если пользователь связан более чем с одним рестораном. • FR-0001-11: Модуль Личного кабинета должен автоматически пропускать этап выбора ресторана, если пользователь связан только с одним рестораном.
Non-Functional Requirements	• NFR-0001-01: Модуль авторизации должен обеспечивать передачу всех данных исключительно по защищенному протоколу HTTPS. • NFR-0001-02: Модуль авторизации должен хранить одноразовые токены входа в хэшированном виде. • NFR-0001-03: Модуль авторизации должен обеспечивать доставку письма со ссылкой для входа не более чем за 30 секунд в 95% случаев. • NFR-0001-04: Модуль авторизации должен обеспечивать корректную работу при одновременной нагрузке до 1 000 активных пользователей. • NFR-0001-05: Пользовательский интерфейс модуля авторизации должен поддерживать локализации RU и EN.
Integrations	• INT-0001-01: Модуль авторизации должен интегрироваться с внешним почтовым сервисом посредством REST API для отправки писем со ссылками для входа.
Risks & Constraints	• R-0001-01: Письма со ссылками для входа могут попадать в спам-папки почтовых сервисов. • R-0001-02: Возможны попытки перебора адресов электронной почты с целью несанкционированного доступа. • R-0001-03: Компрометация одноразовой ссылки возможна при превышении допустимого времени ее действия.
Acceptance Criteria	• AC-0001-01: Пользователь может успешно авторизоваться в Личном кабинете по одноразовой ссылке без участия службы заботы. • AC-0001-02: Одноразовая ссылка становится недействительной после использования или по истечении срока действия. • AC-0001-03: Ограничения на частоту отправки ссылок применяются корректно. • AC-0001-04: Пользователь, связанный с несколькими ресторанами, имеет возможность выбрать активный ресторан после входа в систему.

Детали реализации

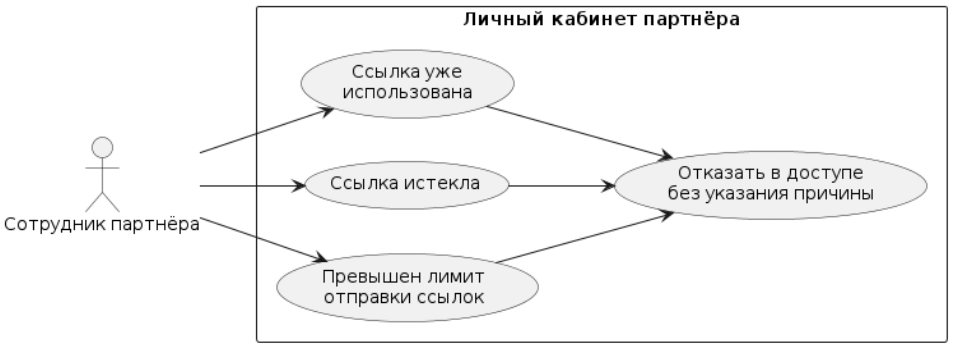
Диаграммы прецедентов

UC-0001-01: Авторизация сотрудника партнёра по одноразовой ссылке (корректный сценарий)



Данный прецедент описывает корректный сценарий авторизации сотрудника партнера в Личном кабинете с использованием одноразовой ссылки, направляемой на электронную почту пользователя.

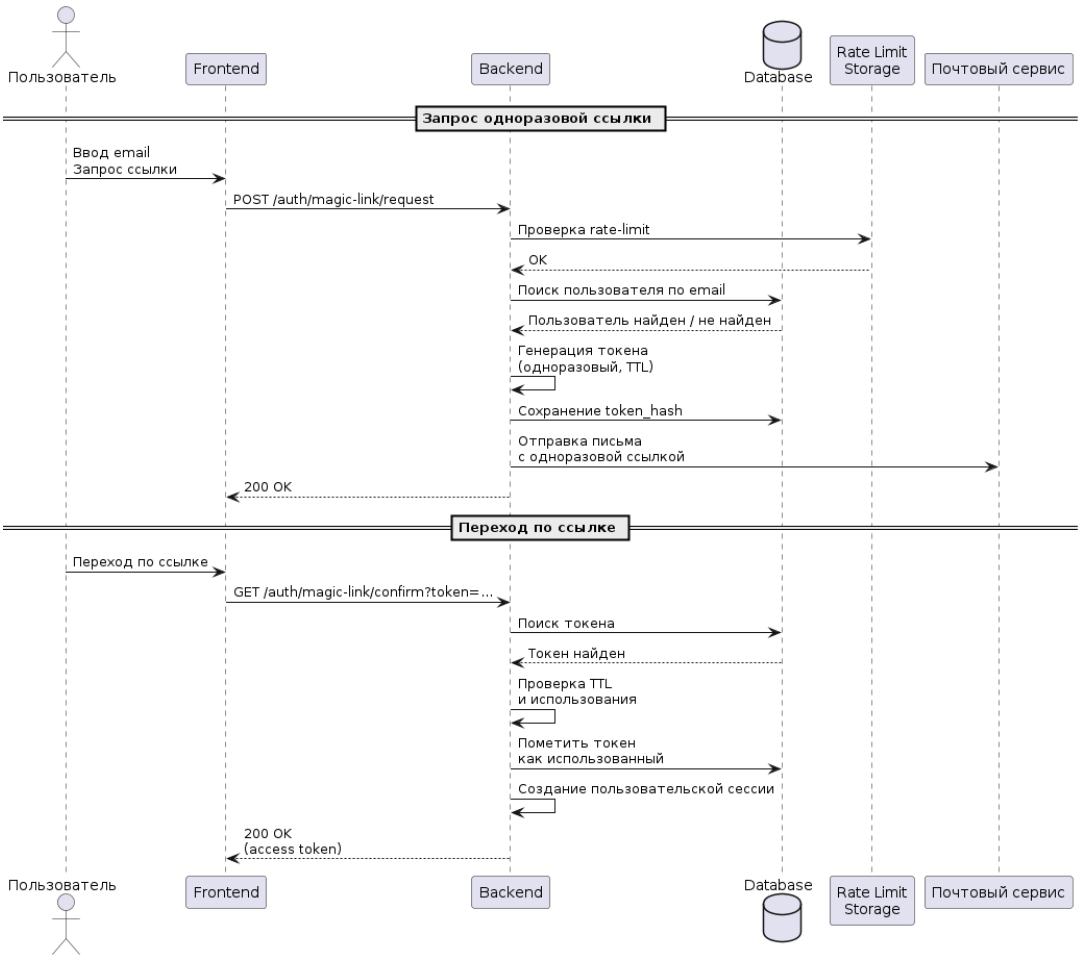
UC-0001-02: Авторизация сотрудника партнера (некорректные сценарии)



Данный прецедент описывает некорректные сценарии авторизации сотрудника партнёра, при которых доступ в систему не предоставляется.

Диаграммы последовательностей

SD-0001-01: Авторизация сотрудника партнёра в системе



Данная диаграмма последовательностей описывает взаимодействие компонентов системы при авторизации сотрудника партнера по одноразовой ссылке, включая frontend, backend, базу данных, in-memory хранилище ограничений и внешний почтовый сервис.

Детали:

- Описание используемых API представлено в главе API Спецификации

API спецификации

API предназначено для авторизации пользователей в системе X с использованием одноразовой ссылки (magic link), направляемой на адрес электронной почты пользователя.

POST `/api/v1/auth/magic-link/request`

Инициирует процесс авторизации пользователя путем отправки одноразовой ссылки для входа в систему на указанный адрес электронной почты.

Параметры запроса:

Параметр	Тип	Обязательный	Описание
`email`	string	Да	Адрес электронной почты пользователя

Пример запроса:

```
{
  "email": "user@restaurant.ru"
}
```

Примеры ответов:

200: Ссылка для входа отправлена.

```
{
  "status": "ok",
  "message": "Если указанный email зарегистрирован, сс
ылка для входа будет отправлена"
}
```

429: Превышен лимит отправки ссылок:

```
{
  "error": "invalid_or_expired_token"
}
```

GET `/api/v1/auth/magic-link/confirm`

Подтверждает одноразовую ссылку и выполняет авторизацию пользователя в системе.

Параметры запроса:

Параметр	Тип	Обязательный	Описание
`token`	string	Да	Одноразовый токен авторизации

Примеры ответов:

200: Пользователь успешно авторизован.

```
{
  "access_token": "jwt-token-here",
  "expires_at": "2026-01-29T10:00:00Z"
}
```

401: Токен недействителен, истёк или был использован ранее.

```
{
  "error": "invalid_or_expired_token"
}
```

GET `/api/v1/auth/session`

Возвращает информацию о текущей пользовательской сессии.

Примеры ответов:

200: Информация о текущей сессии.

```
{
  "user_id": "12345",
  "email": "user@restaurant.ru",
  "restaurant_id": "98765"
}
```

401: Пользователь не авторизован.

```
{
  "error": "invalid_or_expired_token"
}
```

POST `/api/v1/auth/logout`

Завершает текущую пользовательскую сессию.

Примеры ответов:

204: Сессия успешно завершена.

401: Пользователь не авторизован:

```
{
  "error": "invalid_or_expired_token"
}
```

Описание Базы Данных

Таблица `users`

Содержит информацию о пользователях.

Поле	Тип	Обязательное	Описание
`id`	UUID	Да	Уникальный идентификатор пользователя (PK).
`email`	VARCHAR(255)	Да	Адрес электронной почты пользователя, уникальный.
`status`	VARCHAR(50)	Да	Статус пользователя (например, active, blocked).
`created_time`	TIMESTAMP	Да	Дата и время создания записи.
`last_login_time`	TIMESTAMP	Нет	Дата и время последней успешной авторизации пользователя.

Таблица `magic_link_tokens`

Содержит информацию об одноразовых токенах, используемых для авторизации пользователей по ссылке.

Поле	Тип	Обязательное	Описание
`id`	UUID	Да	Уникальный идентификатор токена (PK).

`user_id`	UUID	Да	Внешний ключ, ссылается на `users.id`.
`token_hash`	VARCHAR(255)	Да	Хэш одноразового токена авторизации.
`expires_at`	TIMESTAMP	Да	Дата и время истечения токена.
`used_at`	TIMESTAMP	Нет	Дата и время использования токена.
`created_time`	TIMESTAMP	Да	Дата и время создания записи.

Декомпозиция задач

Целью данного раздела является декомпозиция функциональных и нефункциональных требований на конкретные задачи для реализации, тестирования и внедрения функциональности авторизации пользователей по одноразовой ссылке (magic link) в системе.

Декомпозиция выполнена с привязкой к функциональным требованиям (FR) и может быть использована для формирования бэклога разработки.

Epic EP-0001 - Авторизация пользователей в системе

Реализация механизма идентификации и авторизации пользователей системы X с использованием одноразовой ссылки, направляемой на электронную почту.

Feature FT-0001 - Запрос одноразовой ссылки для входа

Task T-0001-01 - Реализация API запроса одноразовой ссылки

Связанные требования: FR-0001-01, FR-0001-02

- Реализовать endpoint POST`/api/v1/auth/magic-link/request`
- Реализовать приём и валидацию email.
- Обеспечить единообразный ответ API независимо от наличия email в системе.

Task T-0001-02 - Проверка ограничений на частоту отправки ссылок

Связанные требования: FR-0001-03, NFR-0001-01

- Реализовать проверку лимитов отправки одноразовых ссылок.
- Настроить хранение данных о лимитах во in-memory хранилище.
- Обеспечить возврат ошибки при превышении лимитов.

Task T-0001-03 - Генерация и хранение одноразового токена

Связанные требования: FR-0001-04, FR-0001-05

- Реализовать генерацию уникального одноразового токена.
- Обеспечить хэширование токена перед сохранением.
- Сохранять срок действия токена.

Task T-0001-04 - Интеграция с почтовым сервисом

Связанные требования: FR-0001-06

- Реализовать отправку письма с одноразовой ссылкой.
- Обеспечить обработку ошибок почтового сервиса.

Feature FT-0002 - Подтверждение одноразовой ссылки

Task T-0002-01 - Реализация подтверждения одноразового токена

Связанные требования**:** FR-0001-07, FR-0001-08

- Реализовать endpoint GET /api/v1/auth/magic-link/confirm.
- Выполнять проверку существования токена.
- Проверять срок действия токена и факт его использования.

Task T-0002-02 - Создание пользовательской сессии

Связанные требования: FR-0001-09

- Реализовать создание пользовательской сессии при успешной авторизации.
- Обеспечить сохранение времени последнего входа пользователя.

Feature FT-0003 - Управление пользовательской сессией

Task T-0003-01 - Получение информации о текущей сессии

Связанные требования: FR-0001-10

- Реализовать endpoint GET /api/v1/auth/session.
- Возвращать информацию о текущей пользовательской сессии.

Task T-0003-02 - Завершение пользовательской сессии

Связанные требования**:** FR-0001-11

- Реализовать endpoint POST /api/v1/auth/logout.
- Обеспечить корректное завершение пользовательской сессии.

Feature FT-0004 - Безопасность и нефункциональные требования

Task T-0004-01 - Обеспечение безопасности хранения данных

Связанные требования**:** NFR-0001-02

- Обеспечить хранение токенов только в хэшированном виде.
- Исключить утечку чувствительных данных через API.

Task T-0004-02 - Логирование и аудит

Связанные требования: NFR-0001-03

- Реализовать логирование попыток авторизации.
- Обеспечить хранение логов в соответствии с политиками безопасности.

Feature FT-0005 - Тестирование

Task T-0005-01 - Разработка тестовых сценариев

- Подготовить позитивные и негативные сценарии авторизации.
- Проверить работу ограничений на частоту запросов.

Task T-0005-02 - Интеграционное тестирование

- Выполнить тестирование взаимодействия с почтовым сервисом.
- Проверить корректность работы с БД и in-memory хранилищем.

Примечания

- Декомпозиция может быть расширена при уточнении требований и сценариев использования.